INSA
INSTITUT NATIONAL
DES SCIENCES
APPLIQUÉES
LYON



Network Access Control (Contrôle d'accès au réseau)

Walid Bechkit, INSA-Lyon, INRIA-CITI

citi lab

Inria
INVENTEURS DU MONDE NUMÉRIQUE

membre de
UNIVERSITÉ DE LYON

Objectifs du cours

- Comprendre le concept, les fonctionnalités et les composants d'un système de contrôle d'accès au réseau (NAC)
- Comprendre le 802.1X (et le concept du PNAC)
- Comprendre le protocole EAP
- Comprendre le rôle des protocoles AAA et étudier le cas particulier du protocole Radius et de ses extensions
- Comprendre l'interopérabilité 802.1x, EAP, RADIUS
- Comprendre les spécificités Wi-Fi

Principales références

- **Authentification réseau. Radius. 802.1x-EA-FreeRadius**. Serge Bordères, Eyrolles, 2007
- **Comparative Study of Network Access Control Technologies**, Hasham Ud-Din Qazi,, Final Thesis, 2007 Linköpings universitet.
- **Livre Blanc Network Access Control** (Contrôle d'accès au réseau), Enterasys
- **Étude de la mise en place d'une solution de contrôle d'accès au réseau à travers le protocole 802.1X**, Mamadou Bobo Diallo, Mémoire de fin d'études d'ingénieur, 2017.
- Ressources pédagogiques de l'université de Pau et des pays d'Adour (TPs AAA et 802.1X)
- **Sécurité Wi-Fi – WEP, WPA et WPA2** Guillaume Lehembre, 2006
- **802.11 Wireless Networks Security and Analysis**, Alan Holt and Chi-Yu Huang , Springer, 2010
- **Wifi Professionnel - La Norme 802.11, Le Déploiement, La Sécurité,** Aurélien Géron, Broché , 2009

Introduction

NAC: origine et quelques définitions

- Terme métier ancien introduit initialement sous forme de solution d'authentification et d'autorisation

- « Déterminer qui et quoi est autorisé à communiquer sur le réseau depuis un emplacement particulier et à un moment donné (où et quand). »
- « Soumettre l'accès à des ressources par les terminaux à une stratégie de sécurité définie. »
- « S'assurer que chaque périphérique qui se connecte est authentifié et soumis à l'application de règles de sécurité. Automatiser l'administration de l'isolement, de la mise en quarantaine et des menaces. »

NAC: plus qu'une simple authentification

- En plus de l'authentification des utilisateurs et des équipements qui sont au cœur du NAC, il doit pouvoir:
  - restreindre les données auxquelles un utilisateur a accès;
  - réguler les possibilités offertes aux utilisateurs une fois qu'ils sont connectés;
  - exécuter des applications d'analyse et de prévention permanente de risques (détection de logiciels espions, vérification des mises à jour de signatures, etc.)
  - etc.

NAC: fonctionnalités du NAC

1. **Détection des nœuds:** requêtes arp, requêtes d'authentification EAP, requête DHCP, etc.)

2. **Authentification**: déterminer si l'utilisateur ou l'équipement est bien celui qu'il prêtant être

3. **Evaluation de la posture:** vérification des numéros de versions, des mises à jour, des patch, des signatures d'IDS, validité des certificats, etc.

4. **Autorisation:** attribution des droits / privilèges d'accès.

NAC: fonctionnalités du NAC

5. **L'application de la politique de sécurité** (accès intégral, accès limité, mise en quarantaine, accès refusé) : Implémenté par des Access Control List (ACL), VLAN, des règles de firewall (URL-lists, allowed ports …), etc.
6. **Contrôle post admission (et comptabilité)** utilisateurs, équipements, et sessions sont surveillés pour détecter les activités malveillantes (vers, virus, violation des politiques, etc.)
7. **Mise en quarantaine**
8. **Remédiation**

NAC: composants

- **Client: système d'extrémité**

  Machine/utilisateur qui souhaitent accéder aux ressources

- **Le système de mise en conformité (Policy Servers)**

  ex: serveur radius (authentification, autorisation, comptabilité)

- **Le système de contrainte (Enforcement points)**

  ex: point d'accès, switch, routeur, firewall, etc.

  Affecter à et appliquer les règles des VLAN / appliquer les contrôles d'accès N 2,3 ou 4, etc.

- **Réseau de mise en quarantaine**
- **Serveur de remédiation**

NAC: principales solutions

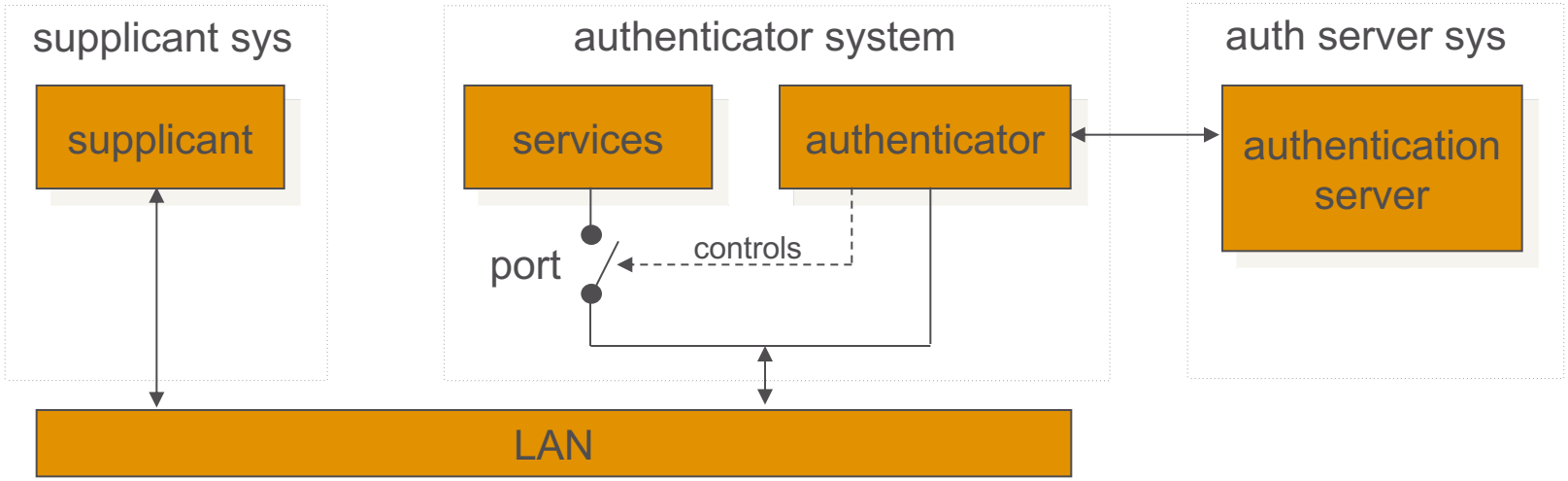
Solutions propriétaires:

- Network Admission Control (NAC) = Identity Services Engine (ISE) - Cisco
- Aruba ClearPass - Aruba
- Unified Access Control (UAC) - Juniper Networks, Inc.
- Network Access Protection (NAP) - Microsoft Corp.

Standards:

- 802.1X: standard IEEE (port-based Network Access Control)
- Trusted Network Connect (TNC) by the Trusted Computing Group: se base sur IEEE's 802.1X, EAP, TLS, et RADIUS, et ajoute des fonctions de couches supérieurs

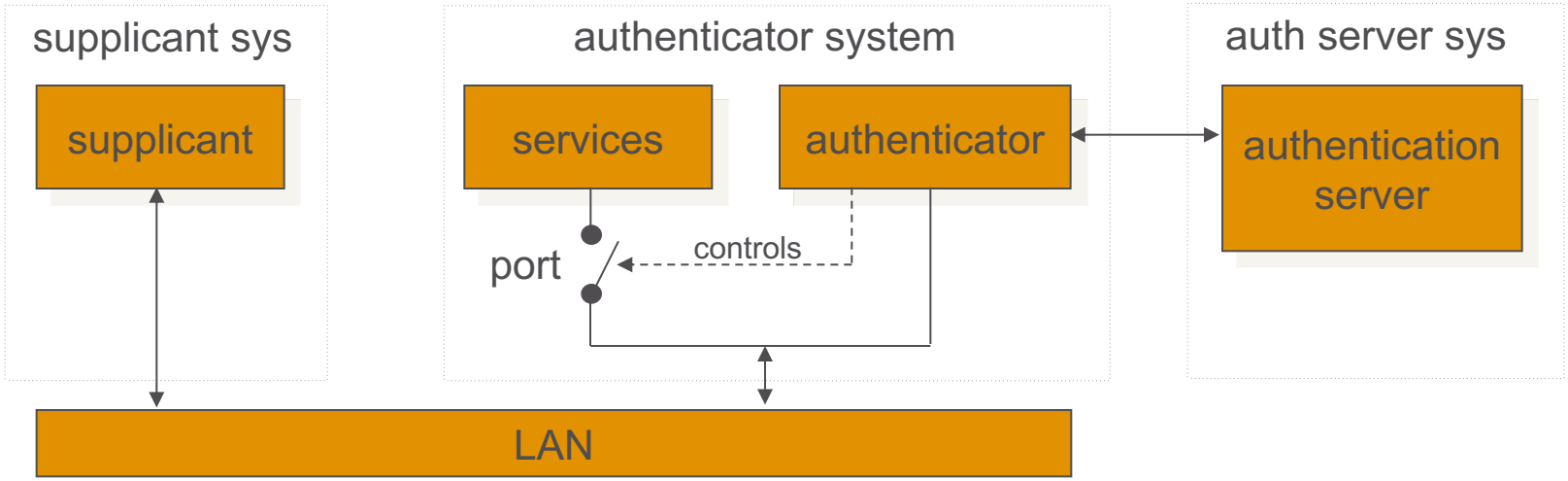
PNAC: modèle d'authentification 802.1X



- Un standard qui fournit un mécanisme d'authentification aux périphériques souhaitant se connecter à un réseau local (filaire ou sans fil)

- Le client (supplicant) demande l'accès à un service (se connecter au réseau)
- Le contrôleur (authenticator) contrôle l'accès au service (l'état du port)
- Le serveur d'authentification (auth. server) autorise l'accès au service

PNAC: modèle d'authentification 802.1X

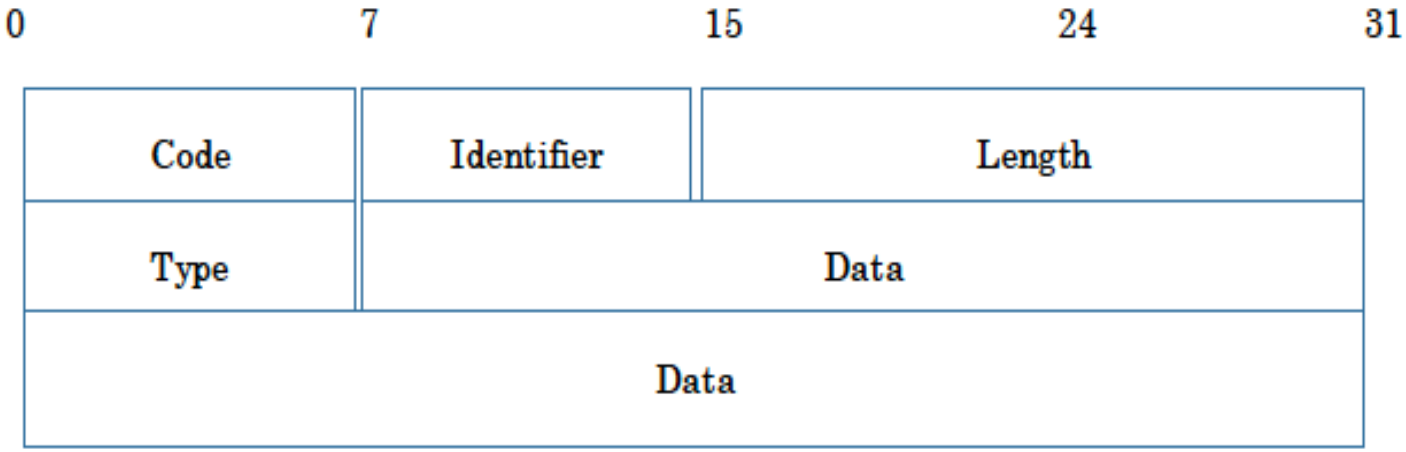


- S'appuie sur EAP pour le transport des information d'authentification (port non contrôlé)
- S'appuie sur un protocole AAA (authentification, l'autorisation, et traçabilité) comme RADIUS, TACACS+, Diameter, etc. :
- La norme 802.1X donne RADIUS comme seul exemple de mise en œuvre mais tout protocole AAA peut etre utilisé.

Protocole EAP

- **EAP (Extensible Authentification Protocol) [RFC 2284, 3748, 5247]**
  - Protocole conçu pour le transport de messages d'authentification (e.g., TLS, TTLS, PSK, MD5, etc.).
  - Attention ! Ce n'est pas un protocole d'authentification
  - Quatre types de messages:
    - EAP request –supplicant → authentication server
    - EAP response –authentication server → supplicant
    - EAP success –successful authentication
    - EAP failure –authentication failure
  - Contrôleur joue un rôle passif et ne connait pas le contenu des messages, il reconnait seulement EAP success and failure

Protocole EAP



Code: type du message contenu dans la trame (Request, Response, Success, Failure)

Identifier: permet de corréler les trames de requête et de réponse.

Length : longueur de la trame.

Type **:** type de protocole utilisé (EAP MD5 ; EAP TLS PEAP ; EAP TTLS ;etc.)

Data :les données transportées par la trame (selon le type)

Protocole AAA

Des protocoles Client / Serveur qui garantissent :

- **Authentification** => Qui parle ?

  Identifier un utilisateur et prouver qu'est bien celui qu'il prêtant être

- **Autorisation** => Quels sont ses « droits » ?

  Attribuer des droits et des privilèges aux utilisateur (droits d'accès aux ressources et aux services)

- **Accounting** => Que fait-il ?

  Enregistrer toutes les informations liées à l'usage d'un service (type de service, début du service, trafic lié au service)

Exemples de protocoles AAA: **Radius**, Diameter, TACACS

Protocole Radius

- **RADIUS:** Remote Authentication Dial-In User Service
- Protocole AAA définit dans les RFC 2865 (Authentification and autorisation) et RFC 2866 (gestion des comptes)
- Utilise le port UDP 1812 pour échanger les données liées à l'authentification des utilisateurs
- Utilise le port UDP 1813 pour la gestion de comptes pour assurer la traçabilité

Authentification Radius

- Rappel : C'est le processus qui s'assure de la légitimité d'une demande d'accès faite par une entité
- Le client Radius (appelé NAS) présente un identifiant au serveur
- Le serveur vérifie que le client est présent dans sa base et que celui qui présente cet identifiant peut prouver qu'il en est le propriétaire.
- Méthodes les plus courantes :
  - Adresse MAC (faible, pas de preuve)
  - Login / mot de passe
  - Certificat

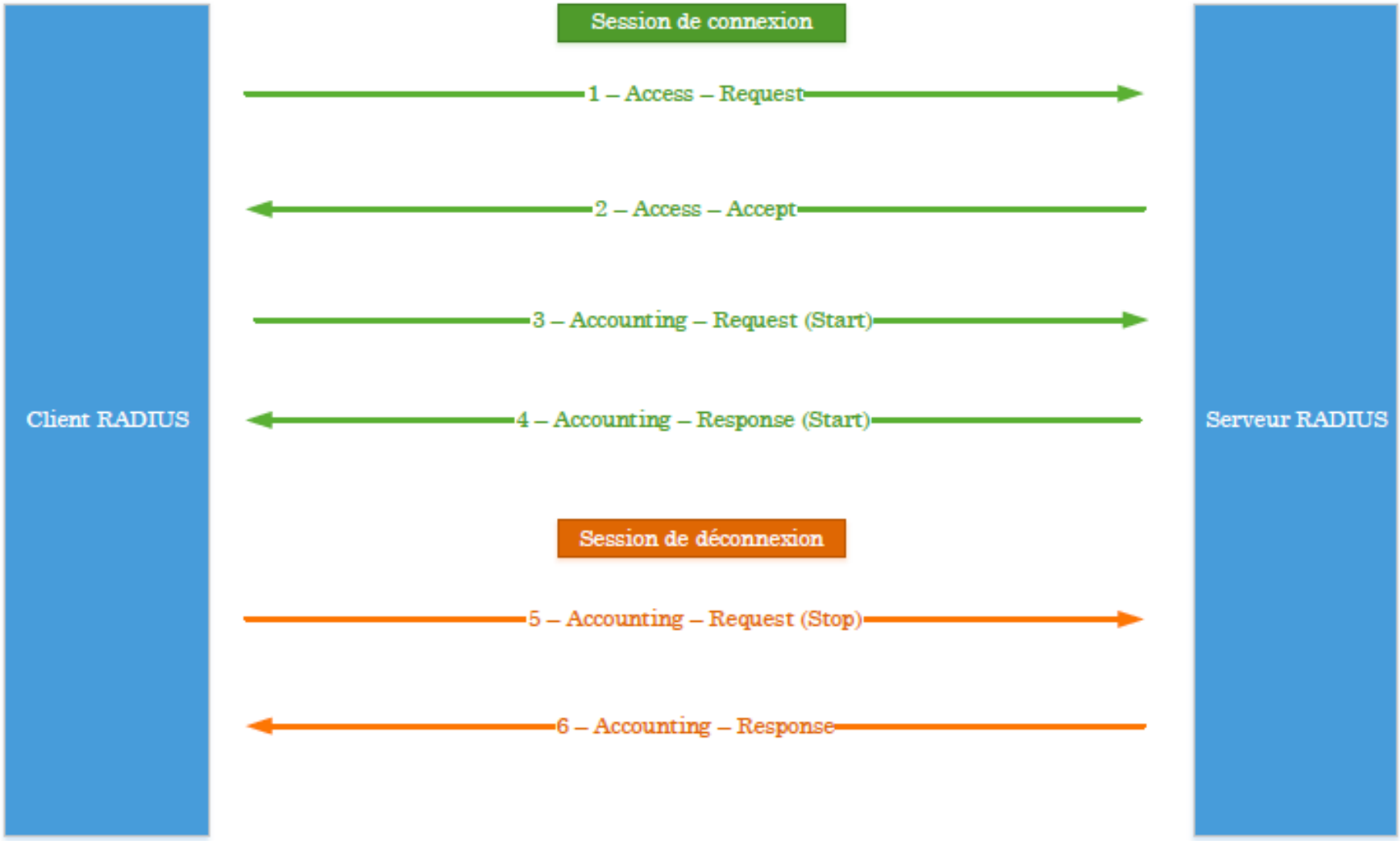
Autorisation Radius

- Accès intégral, accès partiel ou refus de l'accès à un réseau
- Affecter un N°de VLAN
- Positionner des ACLs
- Donner une adresse IP
- Exécuter une commande (filtrage, routage…)
- …

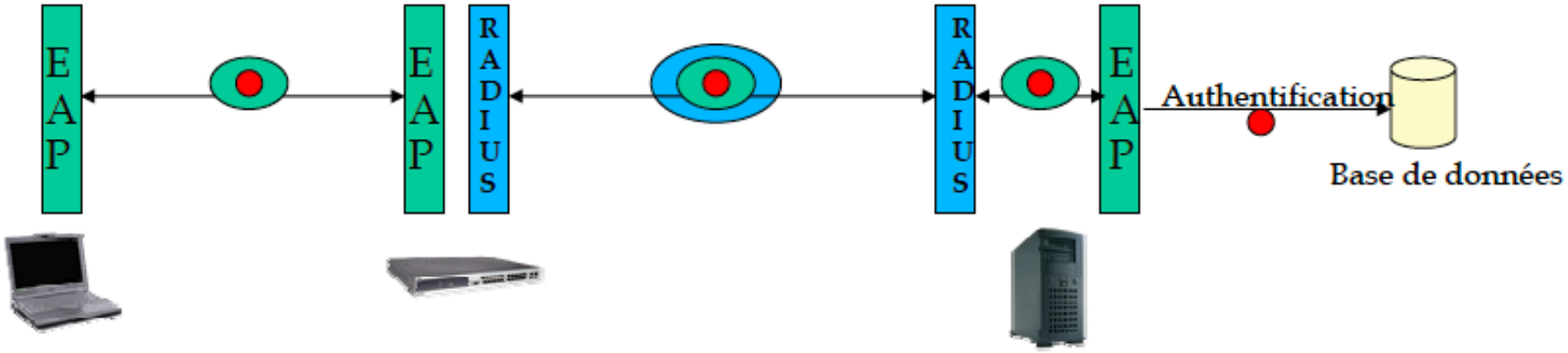
Accounting Radius

- Tracer le début et la fin des sessions
- Tracer les ressources (telles que le temps, les paquets, les octets,) utilisées pendant les sessions
- Permettre entre autres aux FAI de facturer précisément leurs clients

Fonctionnement Radius



Interopérabilité 802.1x, EAP, RADIUS



Protocole d'authentification (charge utile)

Encapsulage EAP

Encapsulage Radius

Base de données Radius

- La base de données associée au serveur Radius contient des informations d'authentification et/ou d'autorisations.
- Cette base n'est pas spécifiée par le protocole Radius
- Avec FreeRadius par exemple :
  - Fichier plat (users): Autorisations et/ou authentification
  - Base LDAP
  - Domaine Windows via Active Directory
  - Base SQL: Autorisation
  - …

Base de données Radius

- Exemple d'un fichier plat (users): Autorisations et authentification

```
DEFAULT
        Tunnel-Type = VLAN,
        Fall-Through = 1


DEFAULT Nas-Port == 10, Nas-IP-Address == 192.168.0.3
        Idle-Timeout = 600,
        Fall-Through = 1

walid User-Password := "test"
        Tunnel-Private-Group-Id = 4

francois User-Password := "test123"
        Tunnel-Private-Group-Id = 5
```

Méthodes d'authentification Radius

Type d'authentification	Emetteur de l'identifiant	Protocole
adresse MAC	l'équipement réseau	RADIUS
login/password certificat	le poste utilisateur (supplicant)	RADIUS + 802.1X + EAP

Méthodes d'authentification Radius

Radius-MAC => Authentification par adresses MAC → Pas recommandé et surtout en sans fil

EAP-MD5 => pas d'authentification mutuelle entre client et le serveur Radius, le client s'authentifie par mot de passe

EAP-PSK => authentification mutuelle entre client et le serveur par secret partagé

EAP-TLS => Authentification mutuelle par certificats

- TLS Handshake - Authentification mutuelle par certificats
- L'identifiant dans la base est le CN du certificat

Méthodes d'authentification Radius

EAP-TLS => **problème**
nécessité de distribuer des certificats à tous les utilisateurs ou machines

EAP-TTLS et PEAP => Authentification du serveur par son certificat et Authentification du client par login/password

Deux phases :

- TLS Handshake – Authentification du serveur par certificat
- TLS Record - Création d'un tunnel chiffré**.** Le protocole d'authentification du mot de passe circule dans le tunnel chiffré

Implémentations Radius

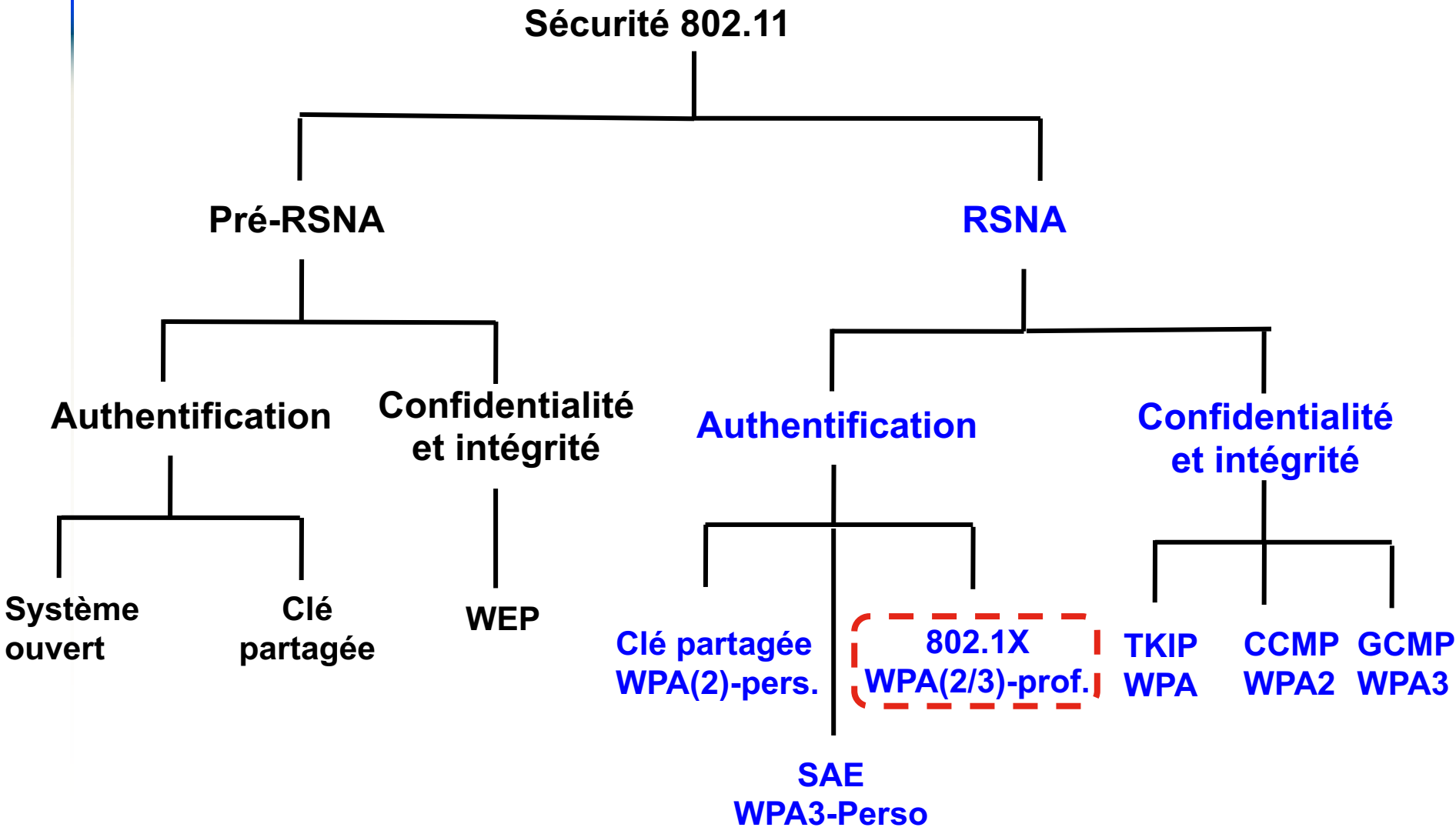
Implémentations Open sources

- Freeradius
- Openradius
- Gnuradius

Implémentations Commerciales

- ACS (Cisco)
- IAS (Microsoft)

Cas particulier WiFi



Phase 2: Correspondence 802.1X / WiFi 802.11i

- Supplicant → Station mobile (STA)
- Authenticator → Point d'accès (AP)
- Authentication server → Serveur qui s'exécute sur le point d'accès ou sur une machine dédiée

- En plus 802.11i intègre:
  - Une authentification réussie se termine par l'envoi d'une clé de session en plus de la réponse positive de l'authentification

Merci ☺